

Table 1: Some encoding schemes

Character	URL encoding	16-bit Unicode encoding	Double URL encoding
dot	%2e	%u002e	%252e
forward slash	%2f	%u002f	%252f
backslash	%5c	%u005c	%255c

can try simple encoded representations of traversal sequences, such as those shown in Table 1.

The time for security

Path traversal attacks can be addressed with the following security measures:

1. There's really no good reason for Apache to be allowed to serve files outside of its document root. Any request for files outside the document root is highly suspect, so we'll restrict it to a directory structure with the following directives in the `httpd.conf` file:

```
<Directory />
    Order Deny, Allow
    Deny from all
    Options none
    AllowOverride none
</Directory>
<Directory www>
    Order Allow, Deny
    Allow from all
    Options -Indexes
</Directory>
```

(Replace the `www` directory name with whatever you've called your Web server's document root. The `Options -Indexes` line in the `<Directory www>` section disables directory browsing, securing the server from directory-traversal attacks.)

2. Apart from this, ensure the user account of the Web server or Web application is given the least read permissions possible for files outside the Web document root. Also, change the default locations of your Web root directories.
3. After performing all relevant decoding and Canonicalisation, of user-submitted filenames,

validate all inputs so that only an expected character set (such as alpha-numeric) is accepted. The validation routine should be especially aware of shell meta-characters such as `/` and `\` and command-concatenation characters (`'&&'` for Windows shells and the semi-colon for UNIX shells).

4. Set a hard limit for the length of a user-supplied value. Note that this step should be applied to every parameter passed between the client and server, not just parameters the user is expected to modify via text boxes or similar input fields.
5. The application should use a pre-defined list of permissible file types, and reject any request for a different type. It is better to do this before the decoding and Canonicalisation has been performed.
6. Any request containing path-traversal sequences should be logged as an attempted security breach, generating an alert to an administrator, terminating the user's session, and if applicable, suspending the user's account.
7. `realpath()` and `basename()` are two functions PHP provides to help avoid directory-traversal attacks. `realpath()` translates any `'.'` or `'..'` in a path, resulting in the correct absolute path for a file. For example, the `$filename` in Attack Scenario 2, passed to `realpath()`, would return just `/etc/passwd`. On the other hand, `basename()` strips the directory part of a name, leaving just the filename itself. Using these two functions, it is possible to rewrite the script of Attack Scenario 2 in a much more secure manner:

RHCVA

(Red Hat Certified Virtualization Administrator)

@ **IPSR**

The future is of Virtualization



Produced
35
RHCSS
Highest in Asia Pacific

Special
OFFER
for
RHCSS
RHCVA

RHCA RHCDs RHCSS RHCVA RHCE

Modules Starting Every Week

Awards

- Winner of Red Hat Asia Pacific International Award 2008, 2009 & 2010
- Winner of Red Hat GLS National Awards 2004, 05, 06, 07 & 08

Faculty & Infrastructure

- 15 member faculty crew led by RHCE, RHCA, RHCSS, RHCDs, RHCA certified professionals
- Global standard infrastructure offered at our International Centre located in Kochi

Achievements

- Produced 3000+ RHCEs, 35 RHCSSs & 3 RHCA

iprs solutions ltd
redefining excellence

Kochi South • Kochi North • Kozhikode
Trivandrum • Kottayam
Tel : 0484 - 2344560, 0481 - 2561410 / 20
Mob: 09447294635, 09447169776
www.iprs.org • training@iprsolutions.com